

IT Security Policy

October 2024

NOTICE		3
1.	Introduction	4
2.	Physical Security Policy	9
3.	Desktop, Laptop and Mobile Device Security Policy	11
4.	Email Policy	15
5.	Encryption Policy	17
6.	Anti-Virus Policy	19
7.	Patch and Update Management Policy	21
8.	Identity and Access Management Policy	22
9.	Asset Management Policy	30
10.	Network Access Control and Connection Policy	33
11.	Remote Access and Virtual Private Network Policy	37
12.	Network Monitoring Policy	41
13.	Server Security Policy	42
14.	Third-Party access Policy	44
15.	Audit Policy	46
16.	Incident Management policy	48
17.	IT Continuity, Back-Up and Recovery Policy	52
18.	Statement of Compliance to the Policy	57
19.	Document Control Panel	58
20.	Approval	59

NOTICE

This policy document is the property of Executive Healthcare Solutions Limited and describes the IT equipment and facilities management as applied to the operations of the company.
Reproduction of this manual, in part or as a whole, is not permitted without the authorization of the Head of IT.

The information contained in this policy document may not be divulged or used for any other purpose other than for which it was intended. The procedures described and related documentation shall not be regarded as legally binding upon the Company.

The right is reserved to amend the contents of this policy document and the procedures referred to therein to reflect any changes to circumstances, methods or products which may apply from time to time.

1. Introduction

1.1. Information Technology Security Policies Document (ITSP) Review Record

This is the revised version of the Information Technology Security Policies Document (ITSP) of the original IT Security Policy of 2019. The changes include adding Version numbers and the effective dates, policy approval section and were necessitated by the need to update the policies for relevancy and Compliance.

ITSP REVIEW RECORD

DOCUMENT'S REVIEW RECORD	Version	EFFECTIVE DATE
ITSP Initial Plan developed	Version 1.0	2022
Information Technology Security Policy Revision	Version 2	16/10/2024

Policy development will normally follow a staged approach to ensure Executive Healthcare Solutions Limited maintains a continuous improvement cycle.

The IT Policy Team will be responsible for ensuring the policy is regularly reviewed and that the timeframe for review is appropriate for a specific type of policy. Review dates should be assigned by the IT Policy Team in consultation with the Senior Management and Stakeholders.

The IT Policy Team in consultation with Senior Management and Stakeholders should ensure that any associated policies are modified or superseded and archived.

The IT Policy Team will monitor the need for an audit to identify whether:

- There is an ongoing need for the policy in relation to its stated purpose and goals and that it remains consistent in relation to the Executive Healthcare Solutions Limited overall strategic plan.
- There is compliance in terms of the way that the policy is being followed.
- There is a potential need to change the policy so as to improve its effectiveness or otherwise to clarify relevant documentation.
- There is a potential need to change the policy to ensure it is up to date and aligns with
- best practice in industry.
- There is compliance with other legislative requirements.
- There is a need to change the implementation process, for instance, when additional
- communication or staff training activities could be required.

The Executive Healthcare Solutions Limited IT Policy Team, which is the team responsible for documenting, issuing and reviewing this Manual welcomes any comments and suggestions aimed at improving the IT Security Policy document.

1.2 Preamble

ICT is a vital component of the Executive Healthcare Solutions Limited business activities.

Information Systems is a critical resource in enabling the company's core activities and for communicating with members of staff, Clients and business partners.

While Executive Healthcare Solutions Limited appreciates that global access to information provides huge opportunities, the company is also aware of many challenges that this access to information may pose.

Today the internet is now resplendent with hackers, virus writers and professional criminal gangs who are always trying to attack the ICT infrastructure of legitimate business organizations.

Executive Healthcare Solutions Limited relies on a secure environment in order to undertake our core business and protection of our *information systems* and information assets is essential.

This IT Security policy is built into the company's risk management framework at the highest level. This Policy applies to all staff members of Executive Healthcare Solutions Limited and those who use the company's *information systems*.

1.3. Objective

The aim of this IT Security Policy is to protect the Executive Healthcare Solutions Limited from security problems with its *information systems* and the information stored on them that might have an adverse impact on its operations, infrastructure or reputation.

It also seeks to raise awareness of information security issues for all staff members of the Company.

1.4. Principles

1.4.1. Scope

The IT Security Policy is purposed to achieve the following:

Confidentiality: Ensuring that information and systems are accessible only to authorized users.
Integrity: Safeguarding the accuracy and completeness of information and processing methods.
Availability: Ensuring that only authorized users have access to information and systems when required.

This policy shall apply to:

- All *information systems* (including *computer equipment*, *network equipment* and telecommunications equipment) owned or operated by Executive Healthcare Solutions Limited or *connected to* the Executive Healthcare Solutions Limited *network* by third parties.
- All software (including operating systems, network services and application software) installed on applicable *information systems*.
- All information stored on applicable *information systems*.

1.4.2. Approach

- Executive Healthcare Solutions Limited will use all reasonable, appropriate, practical, and cost-effective measures to protect its *information systems* and achieve its security objectives.

- The policy will comply with all legal and contractual requirements.
- The policy should be read in conjunction with the **Staff Manual.**

1.4.3. Responsibilities

- All *users* of Executive Healthcare Solutions Limited *information systems* are responsible for protecting information assets.
- *Users* must always act in a responsible, professional, ethical and security conscious way, maintaining an awareness of and conformance with the IT Security policy.
- The Executive Healthcare Solutions Limited Senior Management (through the Head of IT) is responsible and accountable for ensuring that the objectives of the security policy are met.
- The Head of IT is responsible for implementation of this policy and is authorised to pursue activities to achieve the policy objectives.
- The Head of IT is responsible for advising *users* on security issues, preventative monitoring of *information systems* and investigating security incidents.
- *Users* should report any breach in information security or suspected breach to the IT Department.
- Information security best practice and the terms of this policy *shall* be considered at all points in the lifecycle of equipment, software and services developed by, specified by or procured by Executive Healthcare Solutions Limited.

1.4.4. Practices

This IT Security Policy will be reviewed annually to determine whether it still meets the ever-evolving needs of the ICT infrastructure.

1.4.5. Awareness

The IT department will publicise the policy, standards and guidelines to all members of Executive Healthcare Solutions Limited.
Information on known vulnerabilities and patches will be made available to *information systems users.*

1.4.6. Applicability and Enforcement

The IT department will monitor *information systems* and the network to detect unauthorized activity, identify potential weaknesses and proactively prevent security incidents.

This policy and compliance with it apply to all members of Executive Healthcare Solutions Limited and those who use Executive Healthcare Solutions Limited *information systems*.

Appropriate disciplinary action under the Staff Manual for Users of the Executive Healthcare Solutions Limited computing facilities *may* be taken against anyone disregarding the policy.

1.5. Appendix B: Explanation of Terms

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given elsewhere can be found here.

1.5.1. Keywords – Shall, Must, May

The keywords *must, must not, required, shall, shall not, should, should not, recommended, may, and optional* in this document are to be interpreted as follows:

- ***Must***: this word, or the terms ***required*** or ***shall***, means that the definition is an absolute requirement of the specification.
- ***Must not:*** this phrase, or the phrase ***shall not***, means that the definition is an absolute prohibition of the specification.
- ***Should:*** this word, or the adjective ***recommended***, means that there may exist valid reasons in particular circumstances to ignore a particular item, but the full implications must be understood and carefully weighed before choosing a different course.
- ***Should not:*** this phrase, or the phrase ***not recommended***, means that there may exist valid reasons in particular circumstances when the particular behavior is acceptable or even useful, but the full implications should be understood, and the case carefully weighed before implementing any behavior described with this label.
- ***May:*** this word, or the adjective ***optional***, means that an item is truly optional.

1.5.2. Other terms and definitions

The terms and definitions below have the given meaning throughout these policies. Any other computer-specific terms not included here shall be deemed to have the accepted computer industry definition.

Term	Definition
ACS	Access Control Server
Administrator	Any EHS member or other person who is authorised to maintain or administer IT equipment. This would normally be *Head of IT or* IT staff.
Company	Executive Healthcare Solutions Limited
Computer equipment	Any server, workstation, personal computer or laptop.
Connected to the EHS network	Either locally or remotely connected to the network (as defined below).
Department, departmental	Refers to any department, division or other organisational unit of Executive Healthcare Solutions Limited.
Information systems	Any mechanism or method for storing information including but not limited to IT equipment.
Information Technology (IT)	Any *computer equipment* or technological process for storing information.

IT equipment	Any computer equipment, network equipment, telecommunications equipment or handheld device.
Laptop	A portable computer.
Locally connected to the EHS network	Connected to the Executive Healthcare Solutions Limited network via (a) a network access point within Executive Healthcare Solutions Limited offices or (b) via a wireless connection to a wireless network access point within Executive Healthcare Solutions Limited offices.
EHS	Executive Healthcare Solutions Limited.
Mobile device	Any network-enabled mobile telephone or other small footprint device.
Network equipment	Any hub, switch, router, or other equipment used to transport data across a network.
Personal Computer (PC)	A small single-user computer based on a microprocessor.
Personal Data	Data that relates to a living individual that can be identified from that data, or data that when combined with other information that is in the possession of or likely to come into the possession of the data controller that can identify a living individual.
Remotely connected to the Company's network	Connected to the Company's network via a modem, ISDN terminal adaptor, broadband modem, cable modem or other communications device through an account operated by an Internet Service Provider (ISP).
Removable Media	Any type of storage device that can be removed from a computer while the system is running. Examples of removable media include CDs, DVDs and Blu-Ray disks, as well as diskettes and USB drives.
Responsible user	A user who normally operates a specific piece of IT equipment.
Server	A multi-user computer offering services over a network.
Single-user computer equipment	Any personal computer, workstation or laptop that is used by a single person at a time and does not provide significant services to other network users.
Syslog	System log.
User	Any Staff member or other person who is authorised to use IT equipment.
Workstation	A powerful single-user computer with high quality graphics.

2. Physical Security Policy

2.1. Purpose

To establish the requirements for physical security of *information systems.*

2.2. Scope

This policy applies to:

- All EHS owned or operated information systems.
- All third-party IT equipment that is locally connected to EHS's network.

2.3. Policy

2.3.1. Location of Information Systems

- *Information systems should* be housed in a secure area protected by a defined security perimeter with entry controls. *Servers shall be* located within recognised IT Department data centers.
- For the purpose of this Policy the *defined security perimeter* is defined *as 6th Floor, 9 West, Ring Road Parklands Nairobi, Kenya* and *1st Floor, Unit 38, Nyali Center, Mombasa* where Executive Healthcare solutions Head offices and offsite Backup centers are Located respectively.
- For the purpose of this Policy when an Employee is onboarded they will be enrolled onto and Access control system where access to different facilities in the offices is defined and granted

- Physical access to data centers and equipment rooms must be controlled using biometrics or other electronic access control systems and only granted to staff who require such access. Where locks with keys are used, procedures for secure management of the keys must be put in place.
- Access to IT installation centers must be authorized and level of access given by the Head of IT.
- IT servers and telecommunication equipment shall be installed in dust free rooms, which have a high restriction means of access, highly reliable air-conditioning system and a fire security and alarm system.
- IT servers and telecommunication equipment should be mounted in such a way that it shall withstand minimum physical abuse.
- Eating and drinking in the server room is prohibited.
- Proper dress code shall be observed in the server room in order to comply with the OSHA requirements.

2.3.2. Access to IT equipment

Entry control mechanisms *should* be enforced at all times when *IT equipment* is left unattended. Where *IT equipment* is left unattended for significant periods (e.g. overnight or at weekends), additional security measures such as door or window alarms or motion detectors *may* be used.

Unauthorized personnel *should* be permitted into secure areas only when accompanied by authorised personnel.

2.3.3. Protection of IT equipment

Secure areas *shall* be operated and maintained so as to minimize the risk from theft, fire, explosion, smoke, water, dust, vibration, chemical effects, electrical supply interference or radiation.

Backups

IT equipment containing critical or important information assets *shall* have those assets backed up regularly.

Power supply

IT equipment performing critical services or containing critical information assets *should* be fitted with an uninterruptible power supply to allow continued operation or controlled shutdown in the event of electrical supply interruption.

Maintenance

IT equipment should be maintained in accordance with the supplier's recommended service intervals and specifications.

2.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**.

2.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

2.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

3. Desktop, Laptop and Mobile Device Security Policy

3.1. Purpose

To establish minimum security standards for the configuration of personal computers, workstations, laptops, handheld devices, mobile devices and other single-user computer equipment.

3.2. Scope

This policy applies to:

- All single-user computer equipment including personal computers, workstations and laptops locally connected to the EHS network.
- All laptops, handheld devices and other mobile computer equipment that are (from time to time) locally connected to the EHS network.
- All laptops, handheld devices and other mobile computer equipment not connected to the EHS network but contain EHS related business data.
- All users and administrators of the above equipment.

3.3. Policy

3.3.1. New Hardware

Users shall be issued with an Assignment note which they shall sign upon receipt of every IT hardware i.e. rugged laptop, tablets, workstations, laptop, personal computer, printer and scanner, IP Phone, Blackberry, and iPad.

Users should be allocated new hardware in accordance with the following eligibility levels: –

- Laptops, personal computers, printers and scanners will be issued to all levels of employees based on the user's requirements.
- Departmental/Section heads should forward their staff requirements to HR Heads.
- IT support staff shall verify the need for user hardware replacement or disposal.
- All the recommendations for user hardware replacement or disposal shall be forwarded to the IT Officer.
- Rugged laptops, tablets, workstations and other specialized user IT Hardware will be issued to employees upon request to Head of IT through HR Manager.
- IP Phones, iPad and Portable/Mobile Radios will be issued to all levels of employees upon request to the HR Manager.

3.3.2. Returning Hardware

Users shall be issued with a Receipt Note which shall be signed upon returning any issued IT Hardware.

3.3.3. Hardware Movement

Any IT equipment leaving any EHS facility either for repair or being carried away by a third party or contractor shall be issued with a gate-pass.

Returned hardware shall be verified to ascertain that it is in its intended condition before being accepted.

3.3.4. Lost Hardware

Users shall report any lost hardware to the General Insurance department.

The user should present their signed Assignment Note to the General Insurance Department who will advise on any other requirements. At the same time, the user will report to the nearest police station and get a police abstract a copy of which will be given to the General Insurance Department.

The IT Officer shall provide procurement information on the lost item i.e., Invoice Number, Purchase Order to the General Insurance Department for purposes of reimbursement.

The user may be surcharged for the lost item either fully or partially depending on the circumstances leading to the loss.

3.3.5. Retirement of obsolete Hardware

The process evaluation of IT hardware to determine whether it is more economical to repair, upgrade or replace IT hardware components shall be done every month of June in the financial year or upon approval by IT Officer for the purposes of disposing obsolete equipment.

IT hardware shall be considered obsolete if the estimated cost of repair exceeds one–half of the current estimated value or they are damaged beyond repair.

IT hardware and their accessories are considered uneconomical to maintain if the total cost of running them exceeds 60% of the cost of replacement and compatible replacements are not readily available.

3.3.6. Ownership and administration

All *single-user computer equipment must* have a designated person responsible for information security issues. This *may* be a knowledgeable *user* or a *departmental* or IT Department *administrator*.

All *mobile computers must* have a designated person responsible for information security issues. This *may* be a knowledgeable *user* or a *departmental* or IT Department *administrator*.

Responsible users of *mobile devices* or *single-user computer equipment* must inform the designated person, an *administrator* or IT Department (ithelpdesk@executive-healthcare.com) of any known or suspected security-related problem with the *computer equipment*.

Users must keep abreast of security issues for the operating systems they are using. They *shall* be expected to keep up to date with security announcements made by IT Department via IT Representatives.

Users should be aware that mobile computers are at greater risk of exposure to security threats than fixed-location computer equipment permanently connected to the EHS network.

The reasons for this include:

- Maintaining the physical security of a mobile computer in-transit or at an off-site location may be more difficult.
- Theft or loss of mobile computers is more likely, increasing the risk of unauthorized access to data stored on them.
- Mobile computers may be connected to home or third-party networks that are less secure than the Company's network leading to higher risk of exposure to malicious attack.

Computer equipment should be located in secure areas as described in the **Physical Security Policy.**

3.3.7. Single-user computer equipment configuration requirements

- *Computer equipment shall* be configured with a currently supported version of the operating system. Currently supported means that the manufacturer provides security patches or critical updates that protect against new vulnerabilities and that the version has not been designated as 'end of life'.
- *Computer equipment shall* be configured with currently supported versions of software. Currently supported means that the manufacturer or developer provides security patches or critical updates that protect against new vulnerabilities in a timely manner.
- *Computer equipment shall* be configured to provide only the services and resources required by the *users*. Services and applications that are not required *must* be removed or disabled.
- Information, services or resources that are not intended for general public access *shall* be protected by access-control mechanisms (e.g. passwords). Access *shall* be restricted to authorized *users* only.
- If the *computer equipment* provides a security event logging mechanism, this mechanism *shall* be turned on to assist auditing.
- If the *computer equipment* provides other event logging capabilities, this mechanism *should* be turned on to assist with problem diagnosis.
- Security patches *must* be installed on the system as soon as they are available. If an automated facility to check for patches and updates is available, it *should* be used. The only exception to immediate patching is when this would adversely affect an application or service in use by a *user*.
- If a security patch cannot be applied within seven days of release, IT department (ithelpdesk@executive-healthcare.com) *shall* be informed so that alternative security arrangements can be investigated.
- Anti-virus software *shall* be used as described in the **Anti-Virus Policy**.
- *Removable Media* for all *computer equipment* shall be disabled after purchase.
- Services *shall* be run from non-privileged rather than administrator accounts where it is feasible to do so.
- Network communications that involve the transmission of passwords, authentication secrets, *confidential* or *highly confidential* information as defined in the **Asset Management Policy** *must* be encrypted, if a suitable encryption mechanism is available.

3.3.8. Mobile usage requirements

EHS does not require staff to store or access confidential information using computing devices that it does not own or manage. Should EHS require one of its members to use a mobile or home computing device to store or access confidential data, a suitably configured EHS owned device *shall* be provided.

Mobile computers are subject to the same general requirements as fixed location personal computers and *users must* follow the requirements of the **Information Security Policy**.

Access control mechanisms (e.g. passwords, PINs) *must* be used at all times to prevent unauthorized access to mobile computers. If the access control mechanisms are equipped with time-out protection such as automatic log-out or password protected screen locking, these *shall* be implemented. Where possible these *may* be implemented through administrative policies.

Personal firewalls provided as part of the operating system, or a security suite *shall* be turned on and configured to allow only required Information Services.

Mobile communication services such as wireless networking, Bluetooth or infrared *should* be disabled when not in use.

Users **MUST** only use the company provided Assets Only for its authorized purposes. Users should not store *Personal Information* i.e., documents, photos that are not company related on Company provided IT assets.

Disk encryption *must* be used to protect *highly confidential* EHS data as defined in the **Encryption Policy**.

Mobile computers should be located in secure areas, as described in the **Physical Security Policy**, whenever possible. Physical security devices, such as laptop cable locks, *should* be used to protect mobile computers from theft when outside of secure areas.

EHS owned mobile devices may be remotely wiped following report of loss where this service capability exists to Administrators.

3.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Physical Security Policy**, **Anti-Virus Policy, Remote Access Policy** and **Encryption Policy**.

3.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

A *mobile computer* is a *laptop, mobile phone, handheld device* or other item of easily moveable *computer equipment*.

Personal Information for this policy is any information that is not company related i.e., Photos, documents, projects.

3.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

4. Email Policy

4.1. Purpose

To establish the requirements for safe use of electronic mail (email).

4.2. Scope

This policy applies to all *users* who send or receive email via the EHS network or from EHS email systems, whether accessed from on or off site.

4.3. Policy

4.3.1. IT Department responsibilities

All emails entering or leaving the EHS network *shall* pass through the email filtering service and mail relays operated by the IT Department. This includes email passing to or from *departmental* or group mail relays. Email travelling entirely within EHS network is *not required* to pass through the email filtering service.

The email filtering service *shall* provide automated scanning of email to detect potential *malicious code* and to identify *spam*.

Malicious code signatures, *spam* identification rules, block lists and other mechanisms required by email scanning tools to identify new or modified threats *shall* be kept up to date. Checks for updates *shall* be performed at least once a day.

Detection of malicious code

Email items or attachments identified as containing *malicious code* or suspected of containing *malicious code shall* be prevented from reaching the intended recipient. The intended recipient of an infected or suspected email *should* be informed that the email did not reach its destination.

Identification of spam

Email items identified as *spam* or suspected of being *spam shall*, where possible, be quarantined before reaching the intended recipient's mail client. Quarantined email items shall be reported to the intended recipient at regular intervals so that they may confirm the items have been classified correctly. Incorrectly quarantined email items *shall* be released to the intended recipient when requested.

4.3.2. Email *user* responsibilities

Malicious code is developed and released on a regular basis. *Users must* remain vigilant for new threats which automated scanning tools may not yet be able to detect.

Users must not create or modify *malicious code.*

Users must not knowingly send *malicious code* through the email system or otherwise allow it onto the EHS network by other means.

Users must not send, forward or otherwise distribute *spam* or chain letters. Email attachments from unknown sources *must* be scanned for *malicious code* before being

opened.

Since some *malicious code* can fake the sender of an email, messages from known senders that are unexpected or in any way unusual *should* be scanned for *malicious code* before being opened.

Staff *must not* configure their EHS email accounts to automatically forward email to services not operated by the EHS.

Users conducting EHS business or communications via email *must* use an EHS provided email account. Personal email accounts *must not* be used for conducting EHS business or communications.

Phishing

Phishing is a way of attempting to acquire sensitive information such as usernames, passwords and credit card details by masquerading as a trustworthy entity in electronic communication. Communications purporting to be from popular social web sites, auction sites, online payment processors or Information Services are commonly used to lure unsuspecting. *Phishing* is typically conducted by e-mail or instant messaging, and it often directs users to enter details at a fake website whose look and feel are almost identical to the legitimate one.

The IT Department will never request password information via email or telephone and any such request should be reported.

4.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy, Password Policy,** and **Staff Manual for Electronic Mail Usage**.

4.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

Malicious code is defined as any executable, script, macro or other programmable feature that has the potential to damage, control or otherwise compromise the security of a *user's* computer. This includes viruses, trojans, worms and spyware.

Spam is defined as indiscriminate, unsolicited, bulk commercial email. It is often about subject matter that is of no interest, or offensive, to the intended recipient.

Phishing is a targeted email that requests information such as usernames and passwords from the *user* purporting to come from a source of authority.

4.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

5. Encryption Policy

5.1. Purpose

To define the minimum requirements for the safe encryption of data

5.2. Scope

This policy applies to all *users* of EHS *IT equipment*.

5.3. Policy

Encryption is the process of disguising data so as to hide its substance from any casual observer gaining access to it. This is done by applying a mathematical function, known as a *cryptographic algorithm* or *cipher*, to the data to render it unreadable. A mathematical function that reverses the encryption process is used to decrypt the data. One or more unique *keys* is used in conjunction with the *cipher* to perform the encryption or decryption.

5.3.1. General

- Data that is classified as *confidential,* as defined in the **Asset Management Policy**, *should* be encrypted.
- Data that is classified as *highly confidential*, as defined in the **Asset Management Policy**, *shall* be encrypted.
- Data requiring an integrity guarantee *should* be encrypted.
- *Users* requiring strong authentication of a person, service or data item *should* use encryption as part of the authentication technique.

5.3.2. Encryption strength

Only tools and products based on proven, mathematically sound *cryptographic algorithms*, subjected to peer review by the cryptographic community, *shall* be used for encryption.

For block ciphers, a minimum symmetric key length of 128 bits *should* be used. For long term security a symmetric key length of 256 bits is *recommended*. For public key ciphers, a minimum asymmetric key length of 2048 bits *should* be used. For long term security an asymmetric key length of 4096 bits is *recommended*.

All keys *shall* be stored safely. Where a key is secured by use of a *pass phrase*, the *pass phrase shall* be at least twelve characters in length.
The requirements and recommendations for password selection and password protection described in Part **I of the Identity and Access management** *shall* apply for *pass phrases*.

5.3.3. Ciphers and products

The following ciphers are *recommended* for use on EHS *IT equipment*.

- Block Ciphers: 3DES, IDEA, RC5, AES, CAST, Blowfish
- Public Key Ciphers: RSA, Diffie-Hellman
- Hash Functions: MD5, SHA

The following products are *recommended* for use on EHS IT equipment.

- Remote Access: SSH, IPSec, L2TP and PPTP VPNs.
- Web Security: SSL
- Email: Pretty Good Privacy (PGP), TLS, Authenticated SMTP
- File Security: ESET Encryption

Note that some of the above ciphers and products contain patented algorithms or methods which may require the purchase of a suitable license(s).

5.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**.

5.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

- A *cryptographic algorithm* or *cipher* is a mathematical function applied to data to make it unreadable to a casual observer.

- A *block cipher* is a cipher that is applied to a block of data (a number of characters or bits) at the same time. This is different from older ciphers which are applied to a single character at a time.

- A *public key cipher* is a cipher that uses different keys for encryption and decryption. A public key is used for encryption and a private key is used for decryption. The public key cannot be used to decrypt the data and so it can be freely published or given to correspondents that need to send you confidential data.

- A *hash function* is a cipher that produces a unique sequence of characters or numbers (the hash) for any different collection of input data. A hash function can be used to verify that the data has not changed since the hash was generated.

- A *key* is a sequence of characters or numbers, like a password, which is used with a cipher to encrypt or decrypt data.

- A *pass phrase* is a sequence of characters or numbers, like a password, which is often used to gain access to a stored key.

5.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

6. Anti-Virus Policy

6.1. Purpose

To establish the requirements for effective virus detection and prevention.

6.2. Scope

This policy applies to:

- All EHS owned or operated computer equipment connected to the EHS Network.
- All Third-Party computer equipment connected to the EHS Network.
- All users or administrators of the above computer equipment.

6.3. Policy

6.3.1. Use of Anti-Virus software

All *computer equipment* identified by the scope of the policy *shall* have anti-virus software installed and operational. On the first installation of the anti-virus software a full virus scan of all attached storage devices (hard disks) *must* be completed.

6.3.2. Operation for workstations, Personal Computers and laptops

For *workstations, Personal Computers* and *laptops*, if the anti-virus software provides an 'always on' background process, this *must* be turned on. Regular, full virus scans *must* be undertaken.

Where the anti-virus software provides an automatic, scheduled virus scanning capability, this *must* be turned on. For *computer equipment* with 'always on' virus scanning, full virus scans *shall* be scheduled at least once a month. For *computer equipment* without 'always on' virus scanning, full virus scans *shall* be scheduled at least once a week.

Suspicious files received via email, network download, disk, CD or other media from unknown or untrusted sources *must* be scanned for viruses before being opened.

6.3.3. Operation of servers

For *servers*, if the anti-virus software provides an 'always on' background process, this *should* be turned on if this does not significantly affect the performance or operation of the *server*. Regular, full virus scans of the *server must* be undertaken at least once a week. Where a full virus scan affects the performance or operation of the server, it is *recommended* that the scan be performed out of regular office hours, at weekends or during scheduled downtime.

Suspicious files found on the *server* or reported to the *server administrator* that come from an unknown or untrusted source *must* be scanned for viruses before being opened.

6.3.4. Updating virus signatures

Virus signature files *must* be updated regularly. Where the anti-virus software provides automatic checking for new virus signatures, this *must* be turned on. For *computer equipment* with automatic checking, the software *must* be scheduled to check for new virus signatures at least once a day. For *computer equipment* without automatic checking, manual checks *must* be made at least once a week.

6.3.5. Disinfecting Computers

Once a virus is detected the infected files *must* be disinfected, deleted, or quarantined. If the file cannot be disinfected or removed automatically by the anti-virus software, the matter must be referred to the appropriate *administrator* through (ithelpdesk@executive-healthcare.com).

6.3.6. Creation or distribution of viruses

Any activities undertaken with the intention of creating and/or distributing viruses or other malicious code are prohibited.

6.3.7. Exceptions

Exceptions to this policy *shall* only be made in the following circumstances:

- No anti-virus software is available for the platform.
- All available anti-virus software conflicts with essential services or applications running on the *computer equipment* causing the system to crash or become unusable.

6.3.8. Responsibilities

Administrators shall be responsible for ensuring that anti-virus software is installed and operating on all *workstations, personal computers* or *laptops. Users may* request assistance from *the IT Department* in implementing this policy.

Administrators shall be responsible for ensuring that anti-virus software is installed and operating on *servers* or shared *computer equipment*.

6.3.9. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**.

6.3.10. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

6.3.11. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

7. Patch and Update Management Policy

7.1. Purpose

Ensure community are fully aware of the requisite security needed to patch a digital asset and describe the patching controls and constraints to minimize information security risks affecting AUC digital assets.

7.2. Scope

All digital assets must be protected by all means and listed by a rigid and reasonable patching activities. Vulnerabilities should be patched adequately. EHS has the right to protect its assets and ensure its compliance.

7.3. Policy

- All EHS digital assets, systems or services should be patched and updated against any security vulnerability.
- The patching scope includes but not limited to: - operating system, applications, database systems, program components etc.
- All Information Systems shall be maintained to be patched continuously and as fastest as possible.
- This policy is considered a general patch management procedure and shall apply to all Information Systems, digital assets or services by default. Information Systems with specific requirements may be maintained following a specific patch management procedure developed by the Data Custodian and approved by the IT department.
- Patches must be checked for compatibility with all system components prior to being applied. Patches must be successfully evaluated on non-production systems prior to being loaded on production systems, unless otherwise documented in an approved special patch management procedure.
- All patches must obtain the appropriate change control approval prior to deployment on production systems.
- Patching shall be performed during an authorized maintenance time window unless there is an urgent situation.
- Critical system data shall be backed up prior to installation of new patches.
- In general cases, the maximum tolerance time to have EHS systems/services stay unpatched is 10 days.
- According to vulnerability severity, Information Security will decide to shorten this tolerance time to minimize risk to EHS assets and reputation.
- Patching process is the joint responsibility of both system's administrator and application's administrator.

7.4. Patch Management

Information Security oversees the patching process all over EHS, progress reports and new releases should be delivered continuously. A formal and updated asset inventory.

7.5. Exceptions

Exceptions should be as minimum, if they exist should be approved by the IT Department as applicable.

7.6. Enforcement

Any user found to have violated this policy (or part thereof) may be subject to disciplinary action, up to and including termination of employment.

8. Identity and Access Management Policy

8.1. Purpose

This policy describes types of electronic identities in use for systems and applications, criteria for creating identities and accounts, how identities should be authenticated, how authorizations should be managed and how accounts and privileges should be deprovisioned.

8.2. Scope

Part 1 of the policy is applicable to individual account holders. It defines account holders' responsibilities to protect their accounts and effectively use their authorizations.

Part 2 of the policy is applicable to Information System operators responsible for Identity and Access Management for information systems.

This policy focuses on requirements for systems and applications. While it is important to consider encrypting or password-protecting individual files or documents, especially if the files may be sent electronically or stored on a portable device, the intent of the policy is not to set requirements for such individual files or documents.

8.3. Part I: Responsibilities of the Individual

Every person with access to EHS systems is responsible for selecting strong passwords, keeping the passwords secure, and reporting any unauthorized use of accounts. Users must:

- Create passwords that conform to best practices for selecting passwords which address length and complexity.
- Not sharing passwords related to any EHS system with any other person.
- Not using passwords related to any EHS system for non-EHS accounts.
- Immediately change passwords and notify the appropriate system administrator and/or Information Head of IT if there is reason to believe that a password has been improperly disclosed, accessed or used by an unauthorized person.
- Log off or use screen locking technologies that require authentication when leaving a device unattended.
- Use privileges associated with an account only for the purpose for which they were authorized and no more.

8.4. Part II: Responsibilities of IT Staff

This part of the policy applies to all EHS Staff members who configure and/or maintain devices and applications for EHS.

8.5. Accounts

There are three types of accounts at EHS:

User Accounts: These are uniquely associated with a specific person. These accounts may either exist in a central repository to which systems may federate to consume identity and authentication information or they may be created locally on a system or device where federation is not practical or possible. The use of the centrally created account with federated authentication is always the preferred method.

Shared Accounts: Shared accounts are created to support multiple users sharing the same identity. For example, these may be created when there is a need to share a set of resources or because poor product implementation requires it. The use of shared accounts should be discouraged as it lacks accountability.

Service Accounts: A service account is used when it is necessary for systems or applications to authenticate to other systems or applications without any association with a person. These accounts should be created sparingly and documentation of their purpose should be kept. Their use must be periodically reviewed. Further, the password requirements for service accounts must be no less stringent than user accounts. Finally, people may not use service accounts to authenticate aside from initial testing. Service accounts with elevated privileges must be closely monitored for abuse.

Privileged Accounts: Certain accounts may have extra privileges related to the management of a device or application. This is often thought of as an account type, but it is more accurately described as an account with privileged authorizations. Administrative privilege can be added to any of the three account types. Having at least one account with privileges is unavoidable but the use of privilege should be limited and the direct use of shared accounts with privileges should be discouraged as it lacks accountability.

Use privileged accounts and authorizations only when such privilege is needed to complete a function.

Enterprise Directory Services: Information about centrally created accounts and identities are stored in central directory run by Information Technology. The most common implementations of the directory service are Active Directory (AD) and Lightweight Directory Access Protocol (LDAP). EHS information systems should use enterprise directory services whenever possible and avoid creating local accounts and authorizations.

User ID numbers: The primary identifier of a person in our Information Systems is the username login, which is the first letters of the First and Middle name followed by the full Last name. The repository of login names and the technology for assigning an ID number to an individual is maintained by the ICT Department.

Ensuring Uniqueness of a login name: A Login name number must be unique to a single person and each person must only have one login name.

8.6. Authentication

Authentication is the process by which a system or application confirms that a person or device really is who or what it is claiming to be and through which access to the requested resource is authorized. Strong authentication protocols help both to protect personal and EHS information and prevent misuse of EHS resources.
All accounts, centrally defined or not, must require authentication before use.

Types of Authentications

Authentication may take many forms. Authentication is broken down into three types:

Something you know: The most common forms are a password, pin, or pattern.

Something you have: The most common forms are a hardware token, certificate, or a software authenticator like Duo or Google Authenticator.

Something you are: This category is often called biometric authentication and the most common form is fingerprint readers.

Multifactor Authentication (MFA): Involves combining more than one authentication type and provides a stronger assurance of the person's identity. Combining only two of the types is called two-factor authentication (2FA).

Enterprise Authentication Services: Authentication credentials for centrally created accounts and identities are stored in central repositories run by the IT Department. Passwords are stored centrally in a Kerberos database.
We support multifactor authentication through ESET 2FA service to which enrollment is centrally managed by Information Security.

Federated Authentication: Systems and applications may authenticate identities using our enterprise authentication services by federating with them. For systems and non-web applications, federation for password authentication is achieved through direct Kerberos authentication or by joining the system to our Active Directory.

Credentials for accounts that are shared or used by systems or applications must be managed carefully. Follow the following rules when managing these credentials:

- Ensure that only people with a need to know a password have access to it.
- Where reasonable, use multifactor authentication for these accounts, especially on accounts that have privileges such as application or system administrator accounts.
- Where reasonable, require the individual to authenticate to the system as an individual first and then switch to the administrator account, such as the capability provided by the ESET 2FA utility.
- Change the password associated with the account any time a person with knowledge of it ends their affiliation with the Company.
- Avoid saving passwords in scripts and configuration files that can be read by others.
- Where possible, apply secondary measures regarding how these accounts may be used such as by controlling where the accounts are used from (on office only, e.g.) or when (working hours only).

Application and System Administrator Responsibilities

Any person charged with the responsibility of setting up a system or application that requires authentication must configure the system to enforce our authentication policy (below) to the extent possible within the system or application. Variances from the stated authentication policy for Restricted Use systems must be approved by the ICT department.

Authentication Policy
Whenever possible and reasonable, any application or system, whether on premise or in the cloud, should use federated authentication over local accounts and passwords.
The minimum password length is 10 characters. 12 or longer is recommended.
Passwords must be complex. The password must contain at least three of the following four-character sets: Lowercase letters, Uppercase letters, Numbers, Special characters.

Use multifactor authentications for all Restricted Use systems and applications and where

otherwise reasonable to do so. If a system or application that contains Restricted Use information cannot support multifactor authentication a compensating control must be used, and the plan must be approved by the IT Department.

Additional Authentication Recommendations and Compliance Specific Requirements

Consider a policy requiring users to change passwords periodically. This is required for systems containing electronic Protected Health Information (ePHI) covered by HIPAA and credit card data per the Payment Card Industry Data Security Standards (PCI-DSS), regulation.
Consider a policy that prevents users from reusing the same password. This is required for systems containing credit card data per the PCI-DSS regulation.

Consider locking access to accounts after multiple failed authentication attempts within a period of time such as 5 failed attempts in minutes.
Locking accounts after 6 attempts is required for systems containing credit card data per the PCI-DSS regulation. Locked accounts should remain unusable for at least 30 minutes or until unlocked by a system or application administrator.

Local Application Development

Applications that are developed by EHS for use at EHS should be designed to support the requirements of our authentication policy.

8.7. Authorization

Authorizations are implicit or explicit permission to use a resource associated with an account. Once the use of an account is authenticated, a system or resource may determine if the person or software requesting access is authorized to use it. The management and maintenance of authorizations is shared responsibility of ICT department and local system and application administrators.

All units engaged in granting authorizations are encouraged to develop procedures that meet the requirements articulated below in the authorization policy.

Types of Authorizations

There are several types of authorizations to consider.

Birthright Privileges: When an account is created in the EHS Active Directory system, certain authorizations are immediately created with it, such as the ability to authenticate against our enterprise authentication systems, access to our network, and several online resources. Accounts are granted by these authorizations automatically either implicitly or explicitly in the account creation process managed by the IT Department and are sometimes related to the individual user's affiliation with EHS. For some types of guests, it may be possible to customize what these birthright privileges are.

Application and System Administrators must not circumvent the authorizations contained within birthright privileges by, for example, encouraging sharing accounts, creating proxy authentication services to enable users to make requests with the privileges of other users, or creating secondary authentication and authorization systems aimed at bypassing these controls.

System Level Authorizations: Once an account is created on a local system, the account is authorized to access the system and use software and services available to that system. In general, these authorizations are implicit in the creation of an account on the system rather than granted explicitly to the account once created. Some account types have special privileges associated, such as an "administrator", "super-user", or "root" account that is responsible for administrative functions of the system including updating software and managing other accounts.

Application-Level Authorizations: Similar to systems, accounts may have to be explicitly added to applications to enable access; a birthright allocation may be insufficient for an individual's job function and additional authorizations will have to be granted.

Privileged Authorizations: Certain authorizations grant access to administer a system or application and/or access to see data that is created or maintained by others. Privileged access is dependent on the specific person's job duties, not the duties of the person's organizational unit. Information Security is solely responsible for authorizing privileged access to ICT servers and applications that process or store client data and any EHS system containing Restricted Use information.

Principles of Authorization

Least Privilege: An authorization should only provide the privileges required for the function to be performed and no more. Following this principle helps ensure proper workflows are followed and access to functions that may expose data is contained as much as possible.

Separation of Duties: When an authorization is granted to an account multiple individuals must approve it. Multiple approvers ensures that the Principle of Least Privilege is followed from both a technical and process perspective, decreases opportunity for conflict of interest or fraud, and reduces the risk of error. As applied to authorization, separation of duties requires that the administrative and technical approver be not the same person, or if they must be, then the Data Custodian is not filling either role.

Roles in Authorization: Authorizing an account to use a system or application is a distributed responsibility shared by Information Services & Technology, our IT partners, and sometimes external partners who might create authorizations in our direction.

Data Custodians: In general, these authorizations are granted by "Data Custodians," who are entrusted with the maintenance of the data. These are typically Systems Administrators, Database Administrators, or Application Administrators. See the data Access Management Policy for details on this role.
These individuals are responsible for executing the approved account definition/modification/removal request, after validating that appropriate approvals have been granted.

Data Trustees: Data Trustees are leaders entrusted with the responsibility to ensure that EHS data is used appropriately by the Company. Within authorization, they have a special role when approving access to data types that have an associated Trustee.

Administrative and Technical Approvers: All requests for authorization must be approved from an administrative and technical approver. These approvers must be two different people to ensure separation of duties. These approvers are responsible for ensuring the Principle of Least

Privilege is applied from their respective viewpoints.

Administrative Approval: The administrative approval confirms that the authorization requested is needed to perform the required function. The approver should sufficiently understand the full scope of the authorization being granted before deciding and ensure Least Privilege is applied.

Technical Approval: The technical approval confirms that the privilege requested is required to achieve the approved administrative need. The approver should sufficiently understand the full scope of the authorization being granted before deciding and ensure Least Privilege is applied.

ICT Department

The ICT Department is solely responsible for authorizing privileged access to EHS servers and applications that process or store client data and any EHS system containing Restricted Use information. Information Security will confirm that the user to be authorized has signed the appropriate confidentiality agreement(s), taken appropriate training, and/or holds appropriate credentials for accessing the resource.

Application and System Authorizations:

Authorizing access may be automated based on a person's membership in a specific group or a manual process. When authorizing a person to use an application or a system, a Data Custodian must adhere to the following authorization guidelines.

- Use role-based authorization schemes over individual authorizations whenever practical.
- Be as granular as possible in your authorizations.
- Ensure that the authorization has the appropriate approvals: Administrative and Technical Approvals are always required. These approvers must:
    - Ensure the principles of Least Privilege and Separation of Duties are applied.
    - When approving privileges to a shared account consider everyone who has access to that account and whether or not such privilege is appropriate for everyone.
    - All requests for access to data for which there is a Data Trustee must be approved by the Data Trustee.
- All requests for access to a system or application containing Restricted information have been approved by the ICT department.
- Privileged access may be granted permanently only if that specific person's job duties routinely require that level of access, otherwise, the access must be temporary.
- All authorization requests must be documented, including the nature of the request, the time period for which it has been granted, all related approvals that were obtained, and the names of the approvers.

8.8. Deprovisioning

Systems and applications should be designed and deployed in a way that facilitates easy removal of a person's authorizations and accounts at appropriate times.

Centrally Managed Accounts and Authorizations

The enterprise level accounts or authorizations listed in the enterprise directory service and have authentication credentials in our enterprise authentication services shall be deprovisioned in accordance with the policies of our Identity and Access Management policy., adhering to the principles that:

Individuals with no affiliation with EHS should not have an account.
Accounts for individuals with no lasting associations with the EHS, identified as affiliates should only exist for a limited period of time without reauthorization.

Non-Centrally Managed Accounts and Authorizations

When accounts or authorizations are created outside of the enterprise directory and/or enterprise authentication system, the unit creating the accounts must define a mechanism to deprovision the account in a timely fashion (generally within a few business days unless a specific time frame is requested) and consistent with the conditions expressed for centrally managed accounts.

NOTE: It is insufficient to rely on the central deprovisioning of accounts as a method of terminating locally deployed authorizations, as the timeliness of the account deprovisioning is dependent on a number of factors that are beyond the control of the local systems and application administrators.

8.9. Auditing

Audit Trail
Data Custodians are responsible for ensuring that an audit trail of activity exists that includes the following:

- Ensuring that any account or authorization created, deleted, removed, or changed under Section 8.6, 8.7, or 8.8 is audited in a system of record and available for review.
- This log would contain proof of approval for the creation, deletion, removal, or change and the system and any system or application-level log that the account or authorization was modified, if such can be logged.
- Any system or application that authenticates or authorizes an account to take an action should log that activity to a standard location and format. The log should include both successful and failed authentications and authorizations.
- Ensuring that the system or application audit logs are properly configured and function normally over time.

Conducting routine audits of account and authorization activity to ensure that only authorized use is occurring and maintain audit documentation accordingly. As part of this audit:
Provide a list of accounts with privileged access to the appropriate management approvers for review.
Support and encourage periodic review by Data Trustees for information covered under a Trustee's responsibilities.

Account and Authorization Audits:

Information Security and/or Internal Audit may make routine or ad-hoc requests to audit the accounts and authorizations of all EHS information system along with the associated audit trail. These audits will ensure that accounts and authorizations are consistent with this document, including that:

- There is a request for every account with elevated privilege, shared account, or service/process account.
- The request was approved both by an administrative and technical manager.
- The request is compliant with applicable regulation, policy, and best practice.
- The granted privileges were indeed required for the approved administrative use.
- Requests for temporary privileges are expired on the agreed expiration date.
- Every account is held by a person still at the company; and
- The account holder's job function still requires the granted privilege.

8.10. Exceptions

Information Security is authorized to grant exceptions to the requirements set forth in this document. Any exception granted will require a thorough review of the situation and the implementation of appropriate compensating controls.

In addition, Information Security may publish directives aimed at clarifying the intent of a standard to aid in the interpretation of this policy.

8.11. Enforcement

Failure to comply with the Data Protection Standards may result in harm to Clients, organizations EHS.

The unauthorized or unacceptable use of Company Data, including the failure to comply with these standards, constitutes a violation of the EHS IT Security policy and may subject the User to revocation of the privilege to use EHS Data or Information Technology or disciplinary action, up to and including termination of employment.

9. Asset Management Policy

9.1. Purpose

To define the hardware, software and information assets of EHS and its members. To define the minimum requirements for managing these assets in a secure way.

9.2. Scope

This policy applies to all hardware, software and information assets as defined below.

- All *IT equipment* owned or operated by EHS are hardware assets of the EHS.
- All commercial software owned or licensed by the EHS are software assets of the EHS this includes source codes, code units and Developer Licenses.
- The contents of all databases, electronic mailboxes, word processing documents, spreadsheets, web pages, data files, configurations files and other *information systems* created by EHS members in the course of their duties are *information assets* of EHS or its members.

9.3. Policy

Information assets are the ultimate product of the use of hardware and software assets. The creation, manipulation and dissemination of information assets is the lifeblood of EHS.

Information assets *shall* be protected by the secure installation, configuration and updating of *information systems*. Secure installation, configuration and updating of hardware and software assets *shall* be verified, in part, by asset management and tracking.

Users are responsible and accountable for the security of all IT hardware allocated to them either in office or out of the office.

All IT hardware should be clearly and permanently marked as belonging to Executive Healthcare Solutions Limited by the use of a pre-marked aluminum asset tag.

Staff shall take appropriate care of all assets under their care/control. Damage caused to IT hardware as a result of negligence or careless handling may result in the staff being surcharged.

Laptops used in the office should be locked with the security lock when left unattended.

The IT inventory registry must be verified against the asset register with the Finance department at least annually.

9.4. Hardware assets

The IT Department *shall* maintain an inventory of all hardware assets connected to the EHS network. The following information *shall* be maintained as part of the inventory.

- Department
- Location
- Owner (or administrator)
- Media Access Code (MAC) address
- Internet Protocol (IP) address (if fixed)
- Hostname
- Domain name

9.5. Software assets

The IT department *shall* maintain an inventory of all centrally licensed or owned commercial software. The following information *should* be maintained as part of the inventory.

- Software product
- Version
- Number of licensed copies
- Number of installed copies
- Owners or locations of installed copies

Departments and other groups within EHS *should* maintain an inventory of all commercial software licensed or owned by the department.

9.6. Information assets

Information assets *should* be assigned an information classification based on the sensitivity of the information they contain. The classification should be one of the following:

Information Category	Description
Public	This category covers information intended for public consumption or that can be made public without any negative implications for the business activities or reputation of EHS.
Internal	This category covers information regarding the day-to-day business and operations of EHS (suppliers, business partners etc.) but external recipients would be expected to limit access to the information. The information would not be considered of interest to the public and therefore not appropriate for full public access, although public release would not cause serious reputational damage to EHS.
Confidential	This category covers information of a more sensitive nature for the business or operations of EHS. The information represents the company's' basic intellectual capital and expertise. Access should be limited within the organisation to those people who "need to know" for the performance of their duties or studies.
Highly Confidential	This category covers highly sensitive information that if released will cause significant damage to the Company's business activities or reputation or lead to a breach of the data protection act or similar legislation. Access to this information should be very restricted and the number of people who "need to know" will be relatively small.
Personally identifiable information	Personally identifiable information (PII) or individually identifiable health information (IIHI) is any health information that allows the patient to be identified. " It is information, including demographic data, which relates to the individual's past, present or future physical or mental health or condition, the provision of health care to the individual.

If an information asset includes information from different categories, it should be classified as

the most sensitive category,

Each information asset *shall* have an owner. By default, the owner of information assets stored on *IT equipment shall* be the person responsible for the *user* account under which the asset is stored (i.e. the possessor of the asset). Where the assets of multiple owners are collected into a common data store not under the control of a single person (e.g. a database), a notional owner *should* be assigned. The notional owner *may* be a leader or nominated individual of the group collecting information assets into the common data store or an *administrator* for the data storage package. By default, the notional owner *shall* be the data store *administrator*.

Owners or notional owners of information assets *should* classify the relative value of their assets. Risk analysis *should* be performed for all assets that are critical to the operation of the core functions of the Company.

9.7. Developer Tools

Code unit(s), Nav development tools (e.g. compilers, builders, integration tools, test platforms and environments) *Must* be strictly controlled.
To achieve this all Code unit(s) will be achieved by controlling central storage of all system code units.

Read access and write access to code unit(s) will differ based on the personnel's role.
By default, read only access to code units will be broadly provided to all developers.
Write access to code unit(s) *Must* only be made available to privileged personnel or designated owners. Team leaders.

Where code unit(s) components are used by several developers within Executive Healthcare Solutions, read access to a centralized code repository should be implemented.

9.8. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**.

9.9. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

9.10. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

10. Network Access Control and Connection Policy

10.1. Purpose

To establish the requirements and operational principles for the management of network traffic by crossing the boundary between

a) the EHS network and

b) Intranet and the Internet.

To establish the requirements for the connection of *IT equipment* to the EHS network.

10.2. Scope

This policy covers all *IT equipment locally connected to the EHS network and* all network traffic passing between the EHS network and other networks including Intranet and the Internet.

Computer equipment remotely connected to the EHS network is covered by the **Remote Access and Virtual Private Networking Policy**.

10.3. Policy

All access to by EHS network (via wired, wireless & VPN) shall be controlled by EHS's Domain Controller/Active Directory.

Temporary wireless connectivity to the Internet for Guests will be facilitated on request to Head of IT. This wireless connectivity *Must Not* have any connectivity to the production Network and will terminate to an independent gateway separate from the production Network.

A guest account with appropriate permissions, with automatic date and time of expiry shall be activated for temporary use by the guest on approval by the Head of IT.

On resignation/termination of employment, employees will have their network access terminated during the clearing process.

10.3.1. EHS Local Area Network and Wide Area Network.

The EHS network consists of a wired network accessed via plug-in data points in EHS offices and a wireless network accessed via broadcasts from wireless access points around the office.

The EHS wireless network *Must be* encrypted using WPA2 to provide secure authentication based on the Advanced Encryption Standard (AES).

The installation of any non-standard Access Points or wireless devices is prohibited.

The IT Department has the right to disable any non-standard, unauthorised devices which may cause interference with existing approved Access Points or devices. Such devices may be removed without prior notice.

Computer equipment is attached to the wired network by connection to a plug-in data point using a compatible network cable.

Computer equipment with a wireless capability is joined to the network by connecting via a wireless access point using the secure network identifier (SSID: EHS) and authenticating using an EHS username and password.

IT equipment must maintain a hardware address that uniquely identifies it as EHS -wide. For most IT equipment the hardware address will be the Media Access Code (MAC) address associated with the network card.

All EHS owned *IT equipment* to be connected to the wired network *must* be registered with the IT Department prior to connection.

Each connection to the EHS network *shall* provide access to a single computer or mobile device. Multiple computers or mobile devices *shall not* be connected though a single wired or wireless network connection. Multiple devices connected through a single network connection *may* be disconnected from the EHS network.

Personal laptops and mobile devices *Shall Not* be connected to the wireless network or *shall not* be connected the wired network.

Users must not change the hardware address associated with an item of *computer equipment* connected to the wired network or replace or swap a NIC without first registering the change with the IT Department.

All *network equipment* forming the EHS network shall be owned by EHS and managed by the IT department.

All IT *equipment* in use across the Department *shall* be vendor supported. The level of vendor support required shall be such that identified operational problems and security vulnerabilities are rapidly mitigated by vendor provided support.

If any *equipment* on the EHS network is no longer under any type of support from the vendor (standard or extended), the IT product has reached commercial end-of-life plans should be made to replace the equipment as these may pose unacceptable operational and security vulnerability risks.

Computers or mobile devices with the capability to act as wireless access points or network routing devices for other computers or mobile devices *shall not* be connected to the EHS network unless the wireless access point or network routing features are disabled.

The IT Department *shall* supply network settings, including a hostname and IP address, and *shall* ensure that the equipment is configured correctly for network use.

Users connecting *IT equipment* to the EHS network *may* be required to install software to ensure compliance with the **Network Access Control and Connection Policy.**

Where the *IT equipment* is in a fixed location, the IT Department *may* provide a fixed IP address.

Where the *IT equipment* is expected to change locations or not be permanently connected to the network (e.g. a *portable computer*), the IT Department *may* provide a dynamically allocated IP address.

IT equipment using a dynamic IP address *shall* use the Dynamic Host Configuration Protocol (DHCP) to automatically configure network settings.

IT equipment using a fixed IP address *should* use DHCP to automatically configure network settings.

Users must not, at any time:

- Invent network settings or host identities.
- Alter network settings or host identities.
- Transfer network settings or host identities from one computer to another.

10.3.2. Connection

Network traffic passing between EHS network and other networks *shall* be controlled by network access control mechanisms such as firewalls, intrusion prevention systems, network address translators and virus checkers.

Network access control mechanisms *should* be placed at all inter-connection points of the EHS network with other networks. Network access control mechanisms *may* also be placed between subnets of the EHS network.

The IT Department *shall* determine the network services required by *departments*, administrative units and other groups to facilitate the teaching, research and business activities of the EHS.

The IT Department *shall* permit the required network traffic that needs to communicate with other networks to pass through the network access control mechanisms, provided the security of the EHS network is not compromised.

The IT Department *shall* prevent any network traffic from passing through the network access control mechanisms that compromise the security of the EHS network or any other network.

Principle of least access: All network traffic not specifically required to conduct EHS activities *shall* be denied by the network access control mechanisms. Network traffic *should not* bypass the network access controls by means of reverse connections or tunnelling over permitted protocols.

The triplet (source address, destination address, protocol or port) *should* be as specific as possible, consistent with any practical restrictions, when determining network access control rules.

Inbound traffic: New *inbound* traffic from untrusted sources *should* be terminated on servers in the DMZ. There *should* be no unapproved access from external networks to the internal networks. Existing internal servers directly accessible from outside the EHS network *should* be migrated to a DMZ.

The permitted *inbound* protocols *shall* be documented and *may* be published. The following principles apply:

- *Inbound* HTTP, HTTPS and FTP calls *shall* be restricted to identified servers.
- All *inbound* SMTP (Mail) traffic *must* have the destination of one of the established EHS mail relay servers.
- DNS queries and zone transfers *shall* be restricted to identified EHS DNS servers.

Outbound traffic: In general, *outbound* traffic is permitted from any host. Specific protocols *may* be restricted to named hosts or subnets and some protocols *may* be prohibited.

The permitted *outbound* protocols *shall* be documented and *may* be published. The following principles apply:

10.3.3. Logging

Network access control systems *shall* log all denied traffic and *may* log all traffic originating from untrusted or less trusted networks, including Internet and extranet traffic that is destined to the EHS network. Logs *must* be maintained online for at least 7 days, and offline for at least 30 days.

10.3.4. Audit

Network access control system rules *must* be tracked and audited regularly to ensure that unneeded rules are removed. Any rule that is unused within 12 months *may* be removed unless it can be shown to be required.

10.3.5. Change request procedures.

There *must* be an audit trail for every network access control configuration change made. Changes *must* be formally requested and approved by the IT Department. Once the change is approved, records *must* be made of the changes and rollback procedures *must* be used.

10.3.6. Access Control

Logical or physical access to network access control systems *shall* be restricted to authorised personnel. Procedures to log both physical and logical access *should* be put into place.

10.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **IT Security Policy** and the **Network Monitoring Policy.**

10.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

Inbound is defined as initiated from outside of the EHS network.
Outbound is defined as initiated from inside of the EHS network.

10.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action, possibly including loss of network access privileges.

11. Remote Access and Virtual Private Network Policy

11.1. Purpose

To establish the requirements for safe use of remote connections to the EHS network from off site.

11.2. Scope

This policy applies to:

- Remote access policy requirements apply to all *users remotely connecting to the EHS network* from off-Site locations.
- All *users* must use VPN technology to *remotely connect to the EHS network* from off-site locations via the IT Department supported VPN gateway.
- IT staff configuring VPN connections between office locations.

Remote access implementations covered by this policy include, but are not limited to ISDN, ADSL and cable modems which provide narrowband or broadband access to the EHS network via the Internet.

11.3. Policy

11.3.1. General

Remote access *users* should note that by connecting to the EHS they become part of the EHS network and *must* treat any computer connected in this way as if it were on *the EHS Offices.* In particular, they *must* follow the requirements and recommendations of the **IT Security Policy**.

11.3.2. Service requirements

Remote access allows *users* to connect to the EHS network from an internet account provided by an Internet Service Provider (ISP) or third-party network provider. The operation and maintenance of an internet account is a matter for the user and their ISP. EHS plays no part in the provision of the service. Remote access to the EHS network *shall* be made over a secure, encrypted connection whenever this is available. Acceptable secure communication services include VPN, secure sockets layer (SSL), secure shell (SSH) and remote desktop. Insecure communications services *shall* be restricted but *may* be allowed in exceptional circumstances.

Access to services that do not provide a secure, encrypted connection *should* be tunneled through a secure connection whenever possible. It is *recommended* that a Virtual Private Network (VPN) be used if one is available.

Users shall only attempt to connect to computers or services on the EHS network for which they are authorised.

Connections from remote locations *shall* be logged and *may* be monitored as described in the **Network Monitoring Policy**.

Remote access to the EHS network is provided to allow EHS members to perform legitimate administrative activities in conjunction with their work. The use of the connection *shall* be limited to authorised *users* only. The facility *must not* be used by family members or other people at the off-site location.

Remote Access Gateway
Where available, *users should* connect to the EHS network through the use of a Remote Access Gateway rather than directly.

11.3.3. Third-party remote access

Remote access for third parties, such as vendors, *shall* be granted only for legitimate business reasons (e.g. as part of a support contract for the IT Department or equipment).

All third parties requiring remote access *shall* be registered with The IT Department.

Access for third parties *shall* be restricted to the *IT equipment* or services that they are providing. All remote connections *shall* be logged.

11.3.4. Incoming VPN service

The IT Department provides a VPN capability that allows authorised *users* to create a VPN connection from their Internet Service Provider (ISP) internet accounts to the EHS network. The VPN allows access to IT services normally only available from within the onsite network because:

- They cannot be provided securely across the internet or
- EHS network IP address is a requirement to authenticate a *user* as a legitimate member of EHS.

Security for otherwise insecure services is achieved by the VPN by encrypting all network traffic from the *user's* remote computer as it travels over the public internet connection.

The operation and maintenance of an internet account is a matter for the *user* and their ISP. EHS plays no part in the provision of this part of the service. It is also the *user's* responsibility to check that their ISP permits the use of VPN protocols as part of their service agreement.

Access to the EHS network *shall* be via a VPN gateway managed by the IT Department.

All VPN connections *shall* terminate at the VPN gateway. This allows the traffic to be inspected by the EHS firewall and network monitoring tools.
The VPN service *shall* be limited to authorised *users* by means of tokens, certificates, public/private keys, passwords or other authentication mechanisms.
Users *shall* protect any token, certificate, key or password they are given from unauthorised access.
Users *must not* attempt to access any VPN service for which they are not authorized.
Users *must not* allow family members or other unauthorized users to gain access to the VPN service.

Incoming VPN service levels
Different types of VPN access providing different levels of service *may* be provided by the IT Department. These *may* include SSL VPN connections and IPSec VPN connections. Where different levels of access are provided, the IT Department *shall* assess which method a user requires based on their IT needs.

The IT Department *shall* manage the IT services accessible through the VPN to ensure that any additional risk to the security of the EHS network is minimised.

IPSec VPN requirements
For IPSec VPN usage, users *shall* employ:
- A VPN client supplied by IT Department; or
- An IPSec compliant VPN client approved by IT Department.

Users shall ensure that computers *remotely connected to the EHS network* via a VPN pass all network traffic through the VPN tunnel. Traffic for sites on the internet *shall* be passed through the VPN tunnel or *shall* be dropped. Dual or split tunnelling allowing access to the EHS network via VPN and other internet sites via the *user's* ISP *shall not* be permitted as this provides a backdoor for malicious code or users to enter the EHS network.

Users *shall* disconnect from the VPN gateway after twenty minutes of inactivity. Users *must not* use pings or other artificial network mechanisms to keep a connection open when not in use.

SSL VPN requirements
For SSL VPN usage, user *shall* employ:
- An industry standard trusted and secure web browser.

11.3.5. Outgoing VPN connections

Outgoing IPSec VPN connections shall not be permitted (to comply with the **Network Access Control Policy** principle of least access), unless a significant benefit to the EHS can be shown.

Requests to operate an outgoing IPSec VPN connection shall be subject to **Network Access Control Policy** change request procedures and shall be reviewed by IT Department. The requestor shall be required to demonstrate that the security policy implemented at the VPN termination network is at least as rigorous as that at the EHS.

11.4. Responsibility

It is the responsibility of the employee with VPN access to EHS network to ensure no unauthorized user accesses EHS network.

A user shall seek authority to use this service from the immediate supervisor who shall request the provision of this service for the user from the Head of IT.

Only authorised VPN client software shall be installed on users' laptops.

Logs for all network access via VPN/mobile worker technologies shall be kept in appropriate security devices such as the ACS server and Syslog Server.

11.5. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**, the **Anti- Virus Policy**, **Password Policy** and the **Email Policy**.

11.6. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

11.7. Enforcement

Any *user* found to have violated this policy *may* be subject to disciplinary action, possibly including loss of remote access privileges.

12. Network Monitoring Policy

12.1. Purpose

To establish the requirements for monitoring, logging and retention of traffic on the EHS network.

12.2. Scope

This policy applies to:

- All IT equipment locally connected to the EHS network.
- All IT equipment remotely connected to the EHS network whilst the equipment is connected to the EHS network.
- All users of the above equipment.

Users should also be aware that the **Audit Policy** allows for the auditing of *IT equipment* to investigate security breaches and monitor compliance with policy.

12.3. Policy

The IT Department *shall be* authorised to monitor network traffic for operational and security reasons.

Specifically, the IT Department *may* intercept network traffic without consent for purposes such as recording evidence of transactions, ensuring regulatory compliance, detecting crime, gross misconduct or unauthorised use, and ensuring the efficient operation of EHS communications systems.

The primary aims of network monitoring are:

- To maintain the integrity and security of the EHS network, *IT equipment* and Information assets.
- To collect information to be used in network design, engineering, troubleshooting and usage-based accounting.

12.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy** and the **Audit Policy.**

12.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

12.6. Enforcement

Any *user* found to have violated this policy *may* be subject to disciplinary action.

13. Server Security Policy

13.1. Purpose

To establish minimum security standards for the configuration of *servers*.

13.2. Scope

This policy applies to all *servers locally and remotely connected to the EHS network*.

13.3. Policy

13.3.1. Ownership and administration

Servers that provide a service available to *users* external to the EHS network *shall* be configured and maintained by qualified IT staff.

Servers that provide critical or EHS-wide services in support of business functions *shall* be configured and maintained by qualified IT staff.

Server administrators must keep abreast of security issues for the operating systems, services and applications they are maintaining. They *shall* be expected to subscribe to any freely available email or other service that provides them with timely information on security issues or patches.
Servers should be secured in locked racks or areas with restricted access.
All non-removable media should be configured with file systems with access control enabled.
Servers should be set up in an environment with appropriately restricted network access.

13.3.2. Server configuration requirements

Servers must be protected against unauthorised access by:

- changing important security-related parameters to be different from the defaults set by vendors or suppliers.
- invoking time-out facilities that automatically lock out or log off computing devices after a predetermined period of inactivity, clear screens and require users to sign-on again before restoring screens.
- **Integrated Lights-Out** (Ilo) Must always be turned on and configured with strong Passwords.

Servers must be subject to standard security management practices, which include:

- maintaining up-to-date malware protection software to prevent infection by malicious software.
- applying a comprehensive set of system management tools
- monitoring so that events such as attacks against the server can be detected and responded to quickly and effectively.
- using secure technologies to protect insecure services.
- keeping them up to date
- reviewing them on a regular basis to verify configuration settings, evaluate password strengths and assess activities performed on the server.

Physical servers that are used to host virtual servers must be protected against:

- unmanaged and ad hoc deployment of virtual servers
- resource overload by restricting the maximum number of virtual servers that can be created on each physical server.

Hypervisors must be configured to:

- segregate virtual servers according to the confidentiality requirements of information they process.
- logically separate each virtual server to prevent information being transferred between discrete environments.

Servers must be built/configured using a standardised, predetermined server image.

- If a security patch cannot be applied within seven days of release, IT Department (ithelpdesk@executive-healthcare.com) *shall* be informed so that alternative security arrangements can be investigated.
- Trust relationships between systems *shall* be avoided if other suitable authentication mechanisms are available.
- The principle of "least required access" *shall* be used to provide services and resources. Services *shall* be run from non-privileged rather than *administrator* accounts where it is feasible to do so.
- Network communications that involve the transmission of passwords, authentication secrets or restricted information *shall* be encrypted, if a suitable encryption mechanism is available.
- To prevent and detect unauthorized programs from running, systems should be configured to restrict changes to start-up procedures.
- Risks should be mitigated by disabling all unused services.
- Up-to-date anti-virus software and definitions should be used where available. Servers should use a host firewall.
- Where available, host-based intrusion prevention system software should be enabled.
- Host-based intrusion prevention (HIPS) software should be employed on authentication servers

13.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Physical Security Policy** and the **Network Monitoring Policy**.

13.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

A *server* is defined as a multi-user computer that provides a service (e.g. database access, file transfer, remote access) or resources (e.g. file space) over a network connection.

13.6. Enforcement

Any *administrator* or *user* found to have violated this policy *may* be subject to disciplinary action.

14. Third-Party access Policy

14.1. Purpose

To establish expectations for third parties and contractors about maintaining the security of EHS *information systems*.

14.2. Scope

This policy applies to all *third parties* working on *information systems* belonging to or provided for EHS including *formally* or *informally outsourced services*. It also covers:

- Guest-access to EHS systems
- Third party support, maintenance & development

14.3. Policy

14.3.1. Risk

In the absence of control or accountability by the EHS, there is a degree of risk associated with entrusting information to third parties.

- Who may have access to the data
- How user data is used
- Where user data is stored
- Security of user data
- Availability in the short, medium & long term
- Whether user data is recoverable in the event of a disaster
- Availability of support in the event of a problem
- How the facility may change in terms of the user interface or nature of the service

14.3.2. Managing risks

Use of *informally outsourced* services to store sensitive or *personal data* may be in breach of the Data Protection Act.

Informally outsourced services *must not* be approved or promoted for handling confidential information.

An assessment of the potential impact on the EHS that could result from the *third-party* suffering or causing a problem *should* be carried out.

The *third party must* agree to follow this **Information Security Policy.**

14.3.3. Guest access by third parties

Where *third parties* are providing support and maintenance of EHS *information systems* it may be necessary for them to access these systems at the highest level of privilege. It is essential that:

- All such privileged access to or via the EHS network is approved by the IT Department.
- A member of EHS staff is responsible for managing the access in terms of scope, level and duration. All access by *third parties should be* monitored or logged.

- Remote access to *information systems must* only be permitted via secure encrypted network protocols.
- The *third party should* provide EHS with the code of practice that their staff or agents must follow when handling the customer's information. It is preferable that this code of practice forms part of the agreement with the *third party* for provision of service.

EHS members *must not* permit Information security safeguards and policies to be bypassed or allow inappropriate levels of access to EHS *Information systems*.

14.4. Related policies, standards and guidelines

This document should be read in conjunction with the EHS's **Network Access and Connection Policy, Encryption Policy, Remote Access and Connection Policy, and Server Security Policy.**

14.5. Terms and definitions

Third Parties – external organizations or individuals other than the EHS own staff.

Informally outsourced services – Services provided by a third-party company for which there is no formal bilateral agreement or control over data.

Formally outsourced services – Services provided to the EHS by third parties and subject to a formal bilateral agreement or contract, with clear understandings setting out standards and expectations regarding information security.

14.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

Contracts and agreements with Third Parties *should* include means for redress by the EHS in the event of a dispute.

15. Audit Policy

15.1. Purpose

To provide the authority for IT staff to conduct security audits on *IT equipment* in order to investigate security breaches or ensure compliance with EHS policy or other legal or contractual requirements.

15.2. Scope

This policy applies to:

- All EHS owned or operated IT equipment.
- All third-party IT equipment permanently or temporarily connected to the EHS network.
- All users or administrators of the above IT equipment.

15.3. Policy

15.3.1. Reasons for audit

Audits *may* be conducted to:

- Investigate known or suspected security breaches.
- Monitor conformance with the **IT Security Policy** and other legal or contractual requirements.

15.3.2. Authorised personnel

The Head of IT *may* conduct audits on any *IT equipment* within the scope of this policy. Head of IT *may* authorise IT staff to conduct audits on *department IT equipment*. Audits *must* be conducted by authorised IT staff. Auditors *may* request and *shall* expect assistance from *administrators* or *users* responsible for the *IT equipment* being audited.

15.3.3. Limits of audit

The audit *should* only investigate those aspects of *IT equipment* related to its security functions and its compliance with policies and legal or contractual requirements.

15.3.4. Types of audits

Security breach audit

Where the audit is required to investigate a known or suspected security breach, an inspection of the *IT equipment shall* be made to attempt to discover how it was compromised and what damage was caused. The *user* or *administrator shall* facilitate access to the system for the auditor and provide administration level access if requested. The auditor *may* request that the inspection be undertaken by the *administrator* or a suitably knowledgeable *user* under the supervision of the auditor if physical access or other circumstances dictate. Information collected by authorised network monitoring activities *may* also be used in conjunction with information collected during the audit to draw conclusions.

Conformance audit

Where the audit is required to show conformance with policy, the auditor *may* require that the *administrator* or *user* provide evidence that the *IT equipment* complies with policy. An inspection of

the *IT equipment* is *not required* unless the evidence requested is not provided or inconclusive. Automated auditing tools *may* be used in place of manual audits to facilitate the audit process. Information collected by authorised network monitoring activities *may* also be used to confirm or contest the evidence provided.

15.3.5. Audit follow-up

A report *shall* be produced by the auditor describing the findings of the audit and the required actions, if any, to recover from a security breach or ensure compliance with policy. The *administrator* or *user* responsible for the *IT equipment shall* complete all required recovery actions at the earliest opportunity. Copies of audit reports for department *IT equipment shall* be provided to IT Department auditors if requested.

Compromised or non-compliant computers *may* be disconnected from the network or have their network access restricted if their continued connection is deemed to present a serious and significant threat to the security or normal operation of the network or other *IT equipment* connected to the network.

15.3.6. Special situations

Special situations can be considered as follows:

- Where an audit is instigated at the request of a law enforcement agency investigating a criminal matter.
- Where a normal audit uncovers a potential criminal matter.

In the above special situations at least two auditors *must* be present during any inspection of *IT equipment* or during the examination of other information collected by authorised network monitoring. Detailed notes of the investigatory steps taken *must* be made and signed by both auditors on completion of the audit.

Where a normal audit uncovers a potential criminal matter, the audit *must* be stopped immediately, and the *IT equipment* quarantined if possible. The Head of IT or a designated representative *must* be informed, and the Police notified.

15.4. Related policies, standards and guidelines

This policy *should* be read in conjunction with the **Information Security Policy**.

15.5. Terms and definitions

All words or phrases shown in italics are policy terms. Definitions for policy terms not specifically given in this section can be found in appendix B of the **Information Security Policy**.

15.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

16. Incident Management policy

16.1. Purpose

This document describes the procedures which apply to all IT staff for reporting and escalating security incidents and weaknesses.

This policy outlines the responsibilities and procedures for a prompt, effective, and orderly response to security incidents. An appropriate breach notification must be documented. Breach notification procedures may extend across international borders and include cross functional participation, e.g. legal, communications, information management, information security, risk management, and business functions.

16.2. Scope

All EHS owned or operated information systems.

16.3. Policy

16.3.1. Security incident Management

The primary aims of this 'Incident management Policy' are:

- To enable the user to resume work as quickly as possible.
- To apply a level of formality to the management of problems without undue delay to ensure that the resolution is effective, timely, comprehensive and permanent.
- To identify and carry out preventative and corrective action at an appropriate level to the risk and impact of the actual and incipient problems.
- To provide management information on the incidence of problems and the quality of problem resolution, both for appraising performance and for improving service.
-

Security Incident Management involves the following activities:

- Capture and evaluation of security incidents and weaknesses.
- Setting actions to address the security incidents and weaknesses.
- Monitoring progress on the actions.
- Monitoring the overall status of open security incidents and weaknesses. These are described in more detail in the following sections.

16.3.2. Capture and evaluation of security incidents and weaknesses

Anyone within the IT organisation becoming aware of a security weakness or incident (including system failures, loss of service, errors resulting from incomplete or inaccurate business data, breaches of confidentiality) must log this into the helpdesk.

- A security incident is any incident which may affect or has affected the:
- Confidentiality of the organization's (electronically stored) information.
- Integrity of the organization's data.
- Availability of the organization's IT systems.

Initial reporting of an incident is through the helpdesk system. Escalation to IT Projects and Operations Manager where appropriate, may be verbal, by electronic mail or in writing. Issues related to Privacy

should be directed to DPO.
Any identified information security weaknesses and vulnerabilities should be reported as described in IT Security Policy Under no circumstances should any Executive Healthcare Solutions Personnel or contractor attempt to test or exploit an identified weakness or vulnerability unless it is within their job responsibility to do so.
Incidents that involve data breaches (with potential international impact) or any incident with obvious implications beyond the national boundaries should be escalated to the IT officer, who will in return coordinate any further escalation as necessary to Head of IT or any relevant service provider.

16.3.3. Virus Incidents

For the purposes of this policy, the definition of a virus incident is a single occurrence of any number of virus infected files on one computer or fileserver. Where viruses reappear after cleaning procedures have been followed, this shall be considered to be a new incident. Infected files attached to incoming e-mails that are discovered at the e-mail gateway are not considered to be virus incidents, as they have not entered the organization's network.

Individual virus incidents must be reported to the local technical support organisation and resolved within four hours. A central log should be maintained for significant virus incidents. Details of the outbreak will include:

- The name of the virus (if known)
- Description of the symptoms, and payload (if any)
- Over what period it has occurred
- Local action being taken
- Degree of success to date

Where new viruses (viruses which currently issued signature files do not address) are detected, the user should inform the Head of IT, who will be responsible for escalating the incident further as necessary. The Head of IT should contact the antivirus software vendor within 48 hours of being notified. IT officer will take responsibility for rolling out the new signature files/definitions as they are made available by the vendor as quickly as possible.

16.3.4. Resource /Network Attacks

A resource or network attack is one that has the potential to disrupt network traffic or operational systems, or threaten confidentiality, integrity or availability of any component of the network. As soon as any IT personnel become aware of a possible attack, they must notify the Head of IT. Details of the attack will include:

- Description of the symptoms
- Over what period it has occurred
- Action being taken.
- Degree of success to date

The IT department must immediately act to identify and eliminate the source of the attack and, if appropriate, to isolate affected resources or network segments.

16.3.5. Operation Incidents

An operational incident is an event in the central or national network or computer operations caused

by a hardware fault, a software fault, or a legitimate change made to a system by operational staff, which prevents local users or customers from gaining access to or using mission-critical EHS systems. Operational incidents are reported to the local technical support organisation and resolved according to the local Service Level Agreement.
Major incidents that result in non-availability of key systems will be reported to the Group Operations Director and to any member of the EHS leadership team member as necessary.
It will be the responsibility of the Head of IT with Operational groups to ensure that the appropriate security measures are in place, through the audit process, to help minimise the impact of major outages.

16.4. Information Security Continuity

Executive Healthcare Solutions *shall* ensure information security requirements are included in formal business continuity plans (including disaster recovery) formulated to ensure that the business can continue operations after a significant event.

Information security requirements and related processes and procedures, as stipulated in any business continuity plans, *shall* be implemented in the event of an adverse situation that requires the reinstatement of key business services.

Information security requirements as stipulated in any business continuity plans *shall* be reviewed and tested at least annually and corrective action taken to address any deficiencies.
Business critical EHS systems *shall* have adequate provision made for redundant operations.

16.5. Setting Actions to Address the Security Incident or Weakness

A security incident or weakness is usually addressed by specific actions. A security incident or weakness may have any number of actions, each of which as a minimum specifies:

- What the action is
- Who will own the action
- When the action is expected to be resolved

Information security incidents *should* be logged into the Service Desk System. This record/ticket *should* be used to record activities related to the incident and its ultimate resolution (excluding any sensitive or confidential elements which should be logged separately with DPO).
Information security events should be recorded and reviewed (this may be automated) in order to identify incidents that may require a response. Identified incidents should be assessed, classified and prioritized. Results of the assessment and corrective action taken should be recorded.

16.6. Monitoring Open Security Incidents

The head of IT should ensure that all open security incidents and actions against them are reviewed weekly.

EHS *shall* ensure information relating to incidents should be reviewed and analysed regularly to identify any trends by performing a root cause analysis. Based on such root cause analysis, changes to underlying controls should be made to help prevent the issue from recurring. Appropriate recommendations should be made for updating security controls and policies.

16.7. Collection on Evidence

When collecting evidence (by authorized individuals) and prompt investigation of reported information security incidents that affect EHS's information, IT Assets or EHS Personnel. Where necessary, guidance should be sought from local Legal/HR/Risk Management/Security and/or Forensic groups. In all cases, it is imperative to maintain a proper "chain of custody".

In the process of collecting hard copy and electronic evidence, the following approach should be adhered to.

The original evidence must be physically secured. Information such as the person who found it, where it was found, when it was found, and who witnessed the discovery must be documented. Investigations must ensure that originals are not tampered with.

Copies of any removable media, information on hard disks or in memory must be inventoried and physically protected to ensure integrity and availability. The log of all actions during the copying process must be kept, and the process must be witnessed by a member of EHS's management. The log must be securely stored with the media evidence.

In potentially significant or high-risk cases (for example, where the subject matter may possibly lead to legal or regulatory enquiries or claims) legal counsel should be consulted prior to any collection to ensure that the material is collected in such a way as to ensure its integrity and maximize confidentiality/privilege.

This policy *should* be read in conjunction with the **IT Security Policy.**

16.8. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

17. IT Continuity, Back-Up and Recovery Policy

17.1. Purpose

EHS business operations rely on stable and constantly available Information Technology (IT) systems. Effective recovery plans are in place to ensure that IT services can be resumed within required recovery times in the event of a system disruption or disaster.

IT service continuity plans need to be developed to enable the necessary information for critical systems, services and facilities to either continue to be provided or to be reinstated within an acceptable period to the business.

Contingency and disaster recovery refers to the criteria and procedures used to guide management and technical staff in the recovery of computing and network facilities operated by EHS in the event of a disruption or a disaster that destroys all or part of the facilities.

A disruption, loss, damage or compromise of IT systems and data may negatively impact the EHS's reputation and operations, resulting in significant costs to recover. Formal and comprehensive IT continuity, backup and recovery controls are necessary to mitigate such risks.

17.2. Scope

This policy applies to all IT systems, Servers or applications managed by EHS that store, process or transmit information, including network and computer hardware, software and applications.

17.3. Policy

IT administrators are responsible for providing system support and data backup tasks and must ensure that adequate backup and system recovery practices, processes and procedures are followed in line with the Company's Disaster Recovery Procedures.

All IT backup and recovery procedures must be documented, regularly reviewed and made available to trained personnel who are responsible for performing data and IT system backup and recovery.

All data, operating systems/domain infrastructure state data and supporting system configuration files must be systematically backed up - including patches, fixes and updates which may be required in the event of system re-installation and/or configuration.

Copies of backup media must be removed from devices as soon as possible when a backup or restore has been completed.

Backup media which is retained on-site prior to being sent for storage at a remote location must be stored securely in a locked safe and at an off-site location.

17.3.1. IT Continuity Plan

- IT systems that are critical to EHS activities must be clearly identified, as well as the potential risks of disruption that apply to them. Continuity plans are more than just recovery plans and should include documentation of the resilience measures and the measures that have been put into place to enable recovery, together with explanations of why a particular approach has been taken.

- The plan should ensure that all details regarding recovery of the IT services following a disaster are fully documented.

- The recovery plans must include key details such as the data recovery point, a list of dependent systems, the nature of the dependency and their data recovery points, system hardware and software requirements, configuration details and references to other relevant or essential information about the service and system.

- A checklist is a requisite to accompany the plan. It will cover specific actions required during all stages of recovery for the service and system. For example, after the system has been restored to an operational state, connectivity checks, functionality checks or data consistency and integrity checks should be carried out prior to handing the service over to the business/department.

- The IT continuity plan should clearly identify roles and responsibilities.

- Detailed minimum requirements and specifications for the critical IT system components, including mapping of critical applications and data hosted on servers, must be developed.

- Contact information of key resources, including phone numbers (daytime and non- working hours), email and physical address where required:

    - Emergency Response Team, Kenya Power and Lighting Company, and Police.
    - External IT contracts (3rd party IT suppliers, application vendors etc.)
    - Departmental Dependency Contacts (applications and system owners and administrators, customers and stakeholders, communications team, etc.)

- The IT continuity plan must be reviewed and tested at least annually to ensure documented information is up to date and that all team members are aware of their responsibilities, roles and tasks to roll out the plan effectively.

- Regular tests of the IT continuity plan may include the following:

    - High-level plan walkthrough
    - IT Tabletop exercise
    - Simulation exercise
    - Test on communication channels and call procedures
    - Data backup restoration

- A copy of the IT continuity plan must be available off-site (using a laptop for example) at each data center.
- The IT continuity plan will undergo documentation amendment and update post testing and debrief, to address any identified gaps.

17.3.2. Preventative Requirement

- Protection from power failures or other electrical anomalies must be in place, including where possible:
- Multiple power feeds or power supplies.
- Uninterruptible Power Supplies (UPS) with sufficient running time for:
    - Switching to an alternative source of power
    - Backing-up IT systems for transferring data
    - Clean shut down of all IT systems. If equipment supporting critical business operations is not capable of auto-shut down, then the equipment shall be powered down in accordance with an emergency shutdown procedure.
    - Back-up generators or other sources of alternate/secondary power.
- All power to critical IT infrastructure shall be filtered to provide a source of 'clean power'.
- All power supply equipment must be maintained, regularly checked and tested in accordance with the manufacturer's recommended instructions or procedures.
- Surge protection shall be installed, where possible, to all buildings housing critical IT processing or infrastructure equipment.
- Protection from environmental hazards must be in place, including where possible; Hazardous or combustible materials shall not be stored within datacenters or data-rooms.
- Appropriate equipment must be installed in datacenters to monitor and react to fire, flood, high temperature, vibration, air quality and dust hazards.

Exceptions

This policy does not apply to information that is stored locally by users on desktops, laptops, tablets, and mobile phones.

17.4. Responsibilities

17.4.1. Head of IT

- Develop and maintain this, Policy.
- Take proactive steps to reinforce compliance of all stakeholders with this Policy.
- Communicate with the Staff, directly or through Staff representatives, informally or formal instances, to understand the Business needs and expectations, explain the capabilities of the existing technology in production, including backup and recovery capabilities.
- Formally approve backup and restoration activities.
- Formally approve the IT continuity plan.
- Formally report to the Senior Management on any IT disruption of disaster recovery related activities in a timely manner.

17.4.2. ICT Officer

- Ensure tools used for backup and recovery are configured as per this Policy.
- Ensure backups and recoveries are performed without issue and remediate any such issue that arises.
- Answer and address requests to backup or to restore backed-up data or systems.
- Provide recommendations regarding the processes to backup and to recover IT systems,

applications and data, and participate in the development of the BCP/DRP and the IT continuity plan.

- Provide recommendations to improve or update this, Policy.

17.4.3. System Owners

- Identify the critical IT systems, applications and data necessary to support critical business operations.
- Define the minimum availability requirements for their systems, including Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).
- Participate in the development of the BCP/DRP and the IT continuity plan.

17.4.4. Department Managers

- Participate in the development of the BCP/DRP and the IT continuity plan.
- Communicate with the IT group for any need, concern or question related to IT systems availability, ITS backup and recovery services.

17.4.5. Users

- Contact the IT Help Desk for any question or concern related to technology.
- When a question or concern cannot be addressed by the IT Help Desk, contact their supervisor.
- Ensure files are stored in an appropriate location within the scope of backup and restoration activities.

Related Policies Standards and guideline

This policy *should* be read in conjunction with the **Disaster Recovery Plan, the Business Continuity plan**.

17.5. Terms and Definitions

17.5.1. Business Continuity Plan (BCP)

17.5.2.

BCP is a comprehensive plan describing the strategy and necessary activities to recover from a significant disruption of business operations, including the relocation, in part or in whole, all personnel and system resources, making urgent decisions, and conducting business operations with diminished or altered capabilities.

17.5.3. Disaster Recovery Plan (DRP)

A DRP is a documented set of procedures describing the key activities that are necessary to recover minimum services, applications and data to continue critical business operations, and to fully recover such operations after a disruption or disaster affecting normal services.

17.5.4. IT Continuity Plan

An IT continuity plan is a fundamental section of the BCP. It is a documented set of procedures describing the key IT related activities that are necessary to recover minimum IT services, applications and data to continue critical business operations, and to fully recover such operations after a disruption of service or disaster affecting normal IT services.

17.5.5. High Level Plan Walkthrough

Emergency Response Team (Emergency Operations Centre Members) verbally 'walk through' the

specific steps as documented in the plan to confirm effectiveness, identify gaps, bottlenecks or other weaknesses in the plan. Often used in conjunction with previously validated checklist plans. This test provides the opportunity to review the plan with a larger subset of people allowing the company to draw upon a correspondingly increased pool of knowledge and experience. Staff will familiarize themselves with procedures, equipment and offsite facilities as required.

17.5.6. Recovery Time Objective (RTO)

The RTO refers to the maximum tolerable length of time that a computer, system, network, or application can be down after a failure or disaster occurs.

17.5.7. Recovery Point Objective (RPO)

The RPO refers to the maximum amount of time that might pass before the quantity of data lost during that period is considered tolerable.

17.5.8. IT Tabletop Exercise

Discussion-based sessions where team members meet in an informal classroom setting to discuss their roles during an emergency and their responses to a particular emergency situation.

17.5.9. Simulation Exercise

A disaster is simulated so normal operations will not be interrupted. Hardware, software, personnel, communications, procedures, supplies, forms, documentation, transportation, utilities, and alternate site processing should be thoroughly tested in a simulation test.

17.6. Enforcement

Any *user* or *administrator* found to have violated this policy *may* be subject to disciplinary action.

18. Statement of Compliance to the Policy

The IT Department shall be responsible for enforcing these policies and taking appropriate action where there is non-compliance.

Failure to comply with these policies may result in any of the following actions being taken: –

- Cancellation or suspension of use of any IT facilities, systems or technologies
- Payment for loss, damage or repairs
- Civil or criminal liability under applicable laws.
- Disciplinary action under any other appropriate EHS policies including suspension, expulsion or termination of employment
- Any other action that the Company deems fit.

Where otherwise stated or approved, exceptions to this policy MUST have prior approval of the Head of IT (or equivalent) and if it is of a material nature, the Board of Directors must ratify such changes.

19. Document Control Panel

DOCUMENT CONTROL PANEL			
FILE NUMBER		EHS-ITSP-Ver -2.1	
OWNER		IT Department Executive Healthcare Solutions Limited	
HISTORY			
Date	Author Name	Changes	Approver
01/10/2022	AKK	Original ICT Policy	
16/10/2024	AKK	Version numbers and the effective dates, policy approval section and adding IT Continuity, Back Up and Recovery Policy and Whole policy review.	As per Section 19

20. Approval

This IT Security Policy document in its initial form has received the following review and approvals from the management:

Prepared By:
Executive Healthcare Solutions Limited IT Policy Team

Signature and Date: 17/10/2024

Checked By:
IT Officer

Signature and Date: 17/10/2024

Approved By:
IT Projects and Operations Manager

Signature and Date: 17/10/2024

Approved By:
General Manger

Signature and Date: 22-10-24.

Approved By:
Group operations Director

Signature and Date: 22/10/2024

Approved By:
CEO

Signature and Date: 22/10/2024.